Security Assurance Evidence Position

TIO OPERATIONS HUB / CONTROLLED DOCUMENT

TIO-SEC-001 | 2.0 **ISSUED | 24 OCTOBER 2026**

Control field	Controlled value
Document ID	TIO-SEC-001
Version / status	2.0 / Buyer-response draft - disclosure approval pending
Classification	Internal security and assurance working material
Owner / approver	Security owner (proposed) / Legal and executive owner (pending)
Issue date / review	24 October 2026 / Quarterly and before each buyer disclosure
Evidence baseline	Repository materials reviewed 24 October 2026; no independent assessment of a deployment
Supersedes	Initial assurance readiness statement dated 24 October 2026

> **This is not a SOC 2 report, ISO/IEC certificate, audit opinion, penetration-test report, compliance attestation, or security guarantee.**

1. Executive position

The reviewed project materials describe product controls and engineering test evidence for TIO Operations Hub. They do not include an independently issued SOC 2 Type I/II report, ISO/IEC 27001 certificate, certificate scope, external audit opinion, completed independent penetration test, or audited organizational control evidence. Do not state that the product, company, installation, or organization is certified, compliant, audited, or independently tested on the basis of this document.

A customer-managed deployment additionally depends on the actual operating organization: hosting, identity, network, monitoring, patching, access review, personnel, incident response, vendors, backups, continuity, privacy governance and change management. Source code and local tests do not demonstrate operation of those controls.

2. Evidence inventory

Domain	Evidence identified in project materials	Boundary and next evidence
Authentication/access	Documented Forms/Windows modes; roles, scopes, resource/action rights; automated tests	Verify exact release/configuration, IdP, MFA, groups, privileged review and production negative tests
Audit/change history	Audit/event patterns and test results	Establish retention, independent monitoring, review cadence, alerting, tamper resistance and evidence custody
Secure deployment	IIS procedure, SQL least-privilege guidance, package/schema checks	Verify actual TLS, hardening, service identity, network ACLs, secrets, patching and approvals
Data protection	Authorization, export ownership, attachment path controls, configured retention	Assess encryption, key management, locations, access, deletion, backups and actual configuration
Vulnerability management	Build/test process and source	No independent penetration test or complete vulnerability program evidence supplied; obtain scan coverage, SLAs, remediation and retest records
Resilience	Backup/restore guidance and development restore drill reference	Define RPO/RTO; execute production-like recovery, failover and continuity exercises
Availability/capacity	Health endpoints and single-instance design	No uptime commitment, capacity target, independent performance report or scale-out proof supplied
Privacy	Customer-managed deployment model and draft privacy language	Determine roles, jurisdiction, data flow, lawful basis, subprocessors, transfers, residency and retention
Incident response	Draft operational procedure	Assign commander, severity, contacts, notification terms, exercise cadence and evidence
Secure development	Repository tests and release process	Document threat modeling, reviews, dependency controls, vulnerability handling, build provenance and release authorization

3. Product security description - verify for each release

The application materials describe server-side authorization, protected API workflows, separate action grants, access-controlled report generation/download, audit/event history, sign-in modes, health/readiness checks and release-time migration validation. Confirm each characteristic against the exact build and configuration. They do not substitute for independent assessment or operational control evidence.

The documented business visibility policy is not customer-to-customer tenant isolation. The supported architecture is one application instance with in-process workers/cache and configured file storage; this does not establish safe horizontal scale-out. The documented design does not automatically monitor infrastructure, synchronize Jira, retrieve vault secrets or send email.

4. Approved buyer response - pending authorization

Suggested wording only after Security and Legal approval: “We can provide product architecture, deployment documentation and currently available product-level validation evidence for technical review. The materials reviewed for this response do not include a SOC 2 report or ISO/IEC 27001 certificate. The documented deployment is customer-managed; responsibilities, configuration and evidence must be assessed for the proposed environment.”

For each response, record requester, purpose, NDA, exact framework/report requested, product/version, deployment scope, due date, owner, approved response, attachments/redactions and approval. Never answer a formal questionnaire by extrapolating from features alone. Do not disclose internal reports, source code or customer data without the approved disclosure route.

5. Assessment readiness plan

1. Define legal entity, system/service boundary, versions, locations, hosting model, data classes and control owners.
2. Select framework and assessment period with qualified counsel/security leadership; confirm scope with the assessor/certification body.
3. Map each control to policy, system owner, evidence and operating frequency. Separate provider/product responsibilities from customer/operator responsibilities.
4. Establish governance for identity, secure development, change control, vulnerability response, logging, incidents, vendors, backup/continuity and privacy.
5. Collect time-bounded operational evidence: access reviews, approvals, releases, remediation, incident exercises, monitoring, backup and restore.
6. Obtain independent gap assessment, remediate findings and document residual risk.
7. Approve exact report/certificate scope, period, exceptions, audience, NDA and distribution before sharing.

6. Revision history

Version	Date	Change	Approval
1.0	24 Oct 2026	Initial assurance statement	Draft
2.0	24 Oct 2026	Rebuilt as evidence inventory with assessment plan and claim boundary	Security/Legal approval pending